

SOFTWARE REQUIREMENTS SPECIFICATION

StaffDesk

Phase 3 — Governance, Analytics & Performance Management

Change Request CR-2026-021 — Backend Training Program
Client: Crystal Mind — Business Management Solutions

Prepared by	Mazen Adeeb, Engineering Mentor
Prepared for	Ahmed Ghazaly, Backend Developer
Extends	StaffDesk SRS v1.1 (Phase 1) and v2.0 (Phase 2)
Document Version	3.0
Date Issued	1 September 2026
Status	Approved for Development
Engineering Level	Intermediate — feature ownership expected

Document Control

Version	Date	Author	Description
1.0 / 1.1	Jul–Aug 2026	Mazen Adeeb	Phase 1 — directory API and minimal web UI.
2.0	1 Sep 2026	Mazen Adeeb	Phase 2 — organisational structure and task management.
3.0	1 Sep 2026	Mazen Adeeb	This document. Phase 3 — the governance, measurement, and people layers that turn a working task tracker into a system a company can actually run on.

Approval

Role	Name	Signature / Approval
Engineering Mentor / Requester	Mazen Adeeb	Approved
Developer / Feature Owner	Ahmed Ghazaly	Pending acknowledgment

Table of Contents

1. Introduction	3
2. Gap Analysis — What a Complete System Still Lacks	4
3. Architecture Direction	6
4. Part A — Audit, Compliance & Data Governance	8
5. Part B — Completing the Work Cycle	12
6. Part C — Capacity, Availability & Scheduling	16
7. Part D — Analytics & Reporting	18
8. Part E — Performance Management & Employee Ratings	20
9. Part F — Platform & API Maturity	24
10. Part G — Observability & Operations	25
11. Part H — Security & Privacy Hardening	26
12. Non-Functional Requirements	26
13. Out of Scope — Phase 3	27
14. Engineering Process Requirements	28
15. Deliverables & Acceptance Criteria	28
16. Milestones & Sequencing	29
Appendix A — Canonical Metric Definitions	31
Appendix B — Audit Event Catalogue	31
Appendix C — Competency Library & Rating Scale	32
Appendix D — Visibility Matrix	33
Appendix E — Glossary	33
Appendix F — Reference Systems Surveyed	34

1. Introduction

1.1 Purpose

Phases 1 and 2 produced a functioning application: people, departments, hierarchy, and a task system with enforced permissions. What exists now is a *tool*. What a company runs on is a *system* — one that can prove what happened, measure how work actually flows, plan against real capacity, and feed all of that back into how people are managed and developed. Phase 3 specifies that layer.

The requirements here are more demanding than Phase 2's in three specific ways. They involve **derived data** that must stay consistent with its source; they involve **asynchronous processing**, which Phase 2 explicitly forbade; and they involve **sensitive personal data**, where getting the access rules wrong has consequences beyond a failed test. Each of those is called out where it applies.

1.2 Scope

Eight modules, delivered as Parts A through H: audit and data governance; the missing stages of the work cycle; capacity and availability; analytics and reporting; performance management and employee ratings; platform and API maturity; observability and operations; and security hardening. Section 2 explains why each is here by naming the gap it closes.

1.3 Relationship to Earlier Phases

Phase 3 is additive. Every Phase 1 and Phase 2 requirement remains in force and remains testable. Where this document changes prior behaviour it says so explicitly and gives the migration path; there are four such changes, listed in Section 3.4.

1.4 Curriculum References

Day	Training Document	Where it is exercised
14	Reading a Real Codebase	You are now extending a codebase large enough that you cannot hold all of it in your head.
15	Picking Up a Ticket	Each module here is a ticket to be read critically and questioned before code (PE-1).
16	Designing the Feature	A written design note is required per module <i>before</i> implementation (PE-2).
17–18	Implementation, Parts 1 & 2	Branch, business logic, data access, endpoint, validation, tests — repeated eight times.
19	Opening the Pull Request	Self-review and a reviewer-ready description on every module PR (PE-4).
20	Code Review, Merge & Ship	Review response, mergeable state, and a release note per module (PE-5).

1.5 How to Read This Document

Requirement tags are unchanged from Phase 2: **MUST**, **SHOULD**, **MAY**. Requirement IDs are namespaced by module (AU, DG, WC, SL, AP, RW, CP, AN, PM, PL, OB, SP, PE) and are the vocabulary for review comments. Delegated decisions continue to be recorded in docs/decisions.md.

THIS IS NOT ONE SPRINT OF WORK

Phase 3 is deliberately larger than any one deliverable. It is written the way a genuine multi-quarter roadmap is written: complete, prioritised, and explicitly sequenced, so that the parts can be negotiated, deferred, or dropped with full knowledge of what is being given up. Section 16 sequences it into eight increments. Agree with your mentor which increments are in your scope before starting; delivering three modules well is a better outcome than eight half-built ones.

2. Gap Analysis — What a Complete System Still Lacks

This section is the justification for everything that follows. Each row names a capability an operating business expects, states honestly what StaffDesk does today, and identifies the gap. Read it as the reasoning behind the requirements, not as requirements themselves.

2.1 The Work Cycle Is Open at Both Ends

Stage	Today	What is missing	Closed by
Intake	Anyone with access creates a task directly.	There is no request-and-triage step. Work enters the system already accepted, so nothing can be declined, deduplicated, merged, or prioritised against anything else before it becomes someone's problem.	\$5.1
Definition of done	A free-text description.	Nothing states what "complete" means for a given task, so IN_REVIEW is a judgement call with no criteria to judge against.	\$5.2
Commitment	A due date, set by hand, with no consequence.	There are no service targets, no notion of a breach, and no escalation when one happens.	\$5.3
Approval	One reviewer moves the task to DONE.	No multi-party sign-off, no record of what was approved, no distinction between technical review and business acceptance.	\$5.4
Rework	IN_REVIEW → IN_PROGRESS, and the loop is invisible.	Nothing counts how often work is returned, or why. First-pass quality cannot be measured or improved.	\$5.5
Closure	completedAt is stamped and the task disappears.	No outcome classification, no post-completion note, no link from the task to what it actually produced.	\$5.6
Repetition	Every recurring obligation is retyped.	No recurrence, no templates, so routine work is invisible until someone forgets it.	\$5.7
Scale of operation	One task, one action.	No bulk operations and no saved views, so a manager handling forty tasks performs forty requests.	\$5.8

2.2 The System Cannot Account for Itself

Area	Today	What is missing	Closed by
Audit	Task changes are logged. Nothing else is.	Logins, permission grants, role changes, employee record edits, data exports, and reads of sensitive records leave no trace. An auditor asking "who changed this person's manager, and when?" has no answer.	\$4.1–4.3
Tamper evidence	Activity rows are append-only by convention.	Anyone with database access can edit history silently. Convention is not a control.	\$4.4
Retention	Nothing is ever removed.	No retention policy, no purge, no legal hold — the two requirements that always arrive together.	\$4.5
Personal data	Untracked and unclassified.	No inventory of which fields are personal data, no export-on-request, no defensible erasure.	\$4.7

2.3 The Data Cannot Answer Questions

Phase 2 delivered counts: how many tasks are in each status right now. Every question a manager actually asks is about *change over time*, and none of them can be answered:

- “Is work getting faster or slower?” — nothing records how long a task spent in each status, so cycle time cannot be computed even retrospectively.
- “Where does work get stuck?” — blocked duration is not measured; only the current flag exists.
- “Are we improving?” — there is no historical snapshot, so today’s numbers cannot be compared to last month’s.
- “Is this team overloaded?” — workload is a count of open tasks, with no reference to available hours, leave, or task size.
- “Did we hit our commitments?” — on-time completion is not tracked, because commitment is not modelled.

Answering these is Part D (§7). It depends on Part B’s state-duration model (§5.9), which is why the two are sequenced together.

2.4 People Are Modelled, but Not Managed

StaffDesk knows an employee’s level, manager, and workload. It has no concept of how they are *doing*: no goals, no review cycle, no rating, no feedback record, no development plan, and no history to compare against. This is the largest single gap, and the most sensitive to build — Part E (§8) addresses it, with explicit constraints on how task metrics may and may not be used in it.

2.5 The Platform Is Not Ready for a Second Consumer

Concern	Today	What is missing
Retry safety	A retried POST creates a duplicate.	No idempotency keys, so any client with a retry policy corrupts data.
Concurrency	Last write wins, silently.	Two managers editing one task overwrite each other with no warning.
Integration	The web UI is the only client.	No service accounts, no outbound webhooks, no way for another system to react to a change.
Load	No limits.	No rate limiting, no request budget, no protection against a runaway client.
Change management	Endpoints change freely.	No versioning or deprecation policy, so any change is a potential breakage.
Operations	It runs until it doesn’t.	No health endpoints, no metrics, no alerting thresholds, no runbook, no backup and restore procedure.

2.6 Summary

Eleven capability areas are missing. Grouped by the value they deliver, they become the eight parts of this specification: **prove it** (Part A), **complete it** (Parts B and C), **measure it** (Part D), **develop the people doing it** (Part E), and **make it operable** (Parts F, G, and H).

3. Architecture Direction

Phase 3 introduces three structural changes. Design them before you build on them; a wrong choice here is expensive to undo later, which is precisely why Day 16's design step is now mandatory (PE-2).

3.1 Asynchronous Work Is Now Permitted

Phase 2 banned background jobs to keep the system comprehensible. That constraint is lifted, because rollups, exports, webhook delivery, and retention purges cannot be done inside a request. What is permitted is a **database-backed job queue processed by a worker in the same repository** — not an external broker, not a managed queue service.

ID	Requirement	Priority
AR-1	A Job table shall record queued work: type, payload, state (QUEUED, RUNNING, SUCCEEDED, FAILED, DEAD), attempt count, next-attempt time, last error, and timestamps.	MUST
AR-2	A worker process shall claim jobs atomically, so that two workers never process the same job. Demonstrate the claim mechanism in the design note.	MUST
AR-3	Every job handler shall be idempotent: running it twice with the same payload shall leave the same end state.	MUST
AR-4	Failed jobs shall retry with exponential backoff up to a configured limit, then move to DEAD and raise an operational alert (§10.4). They shall never retry indefinitely.	MUST
AR-5	The worker shall be startable independently of the API process, and the system shall remain functional — with rollups merely stale — if the worker is down.	MUST
AR-6	An admin endpoint shall list jobs by state and allow a dead job to be requeued.	SHOULD

3.2 Derived Data and Read Models

Analytics requires data that is computed from, and must stay consistent with, the transactional tables. The rule for every derived structure in this specification is the same, and it is not negotiable:

THE DERIVED DATA RULE

Every derived table must be reproducible from scratch out of the transactional tables alone, by a documented rebuild command that can be run at any time. If a rollup can drift from its source with no way to detect or repair the drift, it is a defect, not a cache. Provide the rebuild command, and prove in the tests that a rebuild produces the same figures as the incremental path.

3.3 Sensitive Domains Are Separated

Performance data (Part E) is categorically different from task data: it is personal, it is restricted to a small set of people, and disclosure is not recoverable. It shall live behind its own service boundary with its own authorization rules (§8.9), and shall not be reachable through generic endpoints — no GET /v1/employees/:id that quietly includes a rating because a query parameter asked for it.

3.4 Breaking Changes to Earlier Phases

#	Change	Migration path
BC-1	Task status transitions now write a status-interval row (§5.9).	Backfill intervals from the existing activity log; tasks predating it get a single synthetic interval, flagged as estimated.

#	Change	Migration path
BC-2	Task gains an intake state; tasks may now exist before being accepted (§5.1).	Existing tasks are migrated as already-accepted. The default list filter excludes unaccepted requests.
BC-3	Mutating endpoints begin honouring Idempotency-Key and If-Match (§9.1–9.2).	Both are optional at first, then required for the endpoints listed in §9.2 after one documented deprecation window.
BC-4	The SystemRole set gains AUDITOR and HR_ADMIN (§8.9, §4.6).	Additive. Existing roles keep their Phase 2 permissions exactly.

4. Part A — Audit, Compliance & Data Governance

4.1 Scope of Auditing

Phase 2's task activity log stays as it is — it is a product feature, shown to users on a task. Phase 3 adds a separate, system-wide **audit log**, which is a control: different audience, different retention, different access rules. Do not merge the two.

	Task activity log (Phase 2)	Audit log (Phase 3)
Audience	Any user who can read the task.	AUDITOR and ADMIN only.
Covers	Changes to one task.	Every security-relevant event in the system.
Purpose	Explaining a task's history to a colleague.	Answering "who did what, when, from where" under scrutiny.
Retention	Lives as long as the task.	Fixed policy, independent of the record it describes (§4.5).
Mutability	Append-only by convention.	Append-only and tamper-evident (§4.4).

4.2 Audit Requirements

ID	Requirement	Priority
AU-1	An AuditEvent shall be written for every event in the catalogue of Appendix B, capturing: event type, actor, actor role at the time, target entity type and id, action outcome (success or denial), a structured before/after where a value changed, source IP, user agent, request id, and a UTC timestamp.	MUST
AU-2	Audit events shall record denials as well as successes . A rejected attempt to read or change a record is the more interesting event of the two.	MUST
AU-3	Authentication events — login success, login failure with reason category, logout, token refresh, token revocation, password change, lockout — shall be audited. Failure events shall never record the attempted password.	MUST
AU-4	Reads of sensitive records — performance reviews, ratings, another employee's time entries, audit data itself, and bulk exports — shall be audited ("access transparency"). Ordinary task reads shall not be, to keep the log signal-bearing.	MUST
AU-5	Audit writing shall not be bypassable from application code: it shall be implemented at a single chokepoint that every mutation passes through, not sprinkled through handlers where it can be forgotten.	MUST
AU-6	A failure to write an audit event for a security-relevant action shall fail the action. Audit is not best-effort. This is the deliberate opposite of the notification rule (NT-3).	MUST
AU-7	Audit events shall be immutable through the API: no endpoint shall update or delete one, including for ADMIN.	MUST
AU-8	Actor identity shall be recorded as a stable employee id plus a denormalised display name captured at write time, so the log remains readable after a rename or a deletion.	MUST
AU-9	Where an action is performed on behalf of another user (delegation, §5.10), both the acting and the effective identity shall be recorded.	SHOULD

4.3 Data Model — AuditEvent

Field	Type	Specification
id	BigInt	Primary key. Monotonic.
occurredAt	DateTime	UTC, set by the server; never client-supplied.
eventType	String	From the Appendix B catalogue.
actorId	Int?	Employee id. Null for unauthenticated events such as a failed login.
actorLabel	String	Denormalised name and role at time of writing (AU-8).
onBehalfOfId	Int?	Effective identity where the action was delegated.
targetType	String?	Entity name, e.g. "Task", "Employee", "PerformanceReview".
targetId	String?	Identifier of the affected record.
outcome	String	SUCCESS or DENIED.
changes	Json?	Structured before/after for changed fields only. Must never contain secrets.
requestId	String	Correlates with the application log (VE-5).
sourceIp	String?	Remote address, honouring any documented proxy header.
userAgent	String?	Truncated to a documented maximum length.
prevHash	String?	Hash of the preceding event (§4.4).
hash	String	Hash of this event's canonical form plus prevHash.

4.4 Tamper Evidence

Append-only by convention means nothing to an auditor. Phase 3 requires that silent modification be *detectable*. The mechanism is a hash chain, which is simple to implement and simple to verify:

ID	Requirement	Priority
AU-10	Each audit event shall store a hash computed over its own canonical serialisation concatenated with the previous event's hash, forming a chain from the first event onward.	MUST
AU-11	A verification routine shall recompute the chain over any range and report the first index at which it breaks. It shall be exposed as an ADMIN endpoint and be runnable from the command line.	MUST
AU-12	The canonical serialisation shall be deterministic — fixed field order, fixed number and date formatting, explicit null handling — and shall be documented, because a chain that cannot be reproduced byte-for-byte cannot be verified.	MUST
AU-13	Chain writes shall be serialised so that concurrent requests cannot interleave and produce two events claiming the same predecessor. State how you achieve this in the design note.	MUST
AU-14	The verification routine shall be exercised by a test that deliberately corrupts a stored event and asserts that verification fails at exactly that point.	MUST

BE HONEST ABOUT WHAT THIS PROVES

A hash chain in the same database as the data proves that history was not altered *without leaving evidence*. It does not prevent an administrator with write access from rewriting the whole chain. Real *tamper-proofing* needs the chain, or a periodic anchor of it, held somewhere the administrator cannot reach. Note this limitation in the README rather than overstating the control — an honest description of a partial control is a professional deliverable; an overstated one is a liability.

4.5 Retention, Purge and Legal Hold

ID	Requirement	Priority
DG-1	A retention policy shall be defined per data class — audit events, task activity, notifications, soft-deleted tasks, closed performance reviews, session records — as configuration, not as constants scattered in code.	MUST
DG-2	A scheduled purge job (§3.1) shall remove data past its retention period, shall itself write an audit event recording the class and row count removed, and shall never remove the audit events describing purges.	MUST
DG-3	Purge shall run in bounded batches and shall be safely resumable after interruption.	MUST
DG-4	A legal hold shall be placeable on an employee or a task. Held records shall be exempt from purge and from erasure until the hold is lifted; placing and lifting a hold shall itself be audited.	MUST
DG-5	A dry-run mode shall report exactly what a purge would remove without removing it. No destructive job ships without one.	SHOULD

4.6 Audit Access and Export

ID	Requirement	Priority
AU-15	An AUDITOR role shall be introduced: read-only access to the audit log across the whole organisation, and no access to modify anything, including no ability to read task or performance content beyond what an audit event contains.	MUST
AU-16	The audit query endpoint shall filter by actor, target type and id, event type, outcome, date range, and source IP, and shall use cursor pagination (§9.3) because result sets are large.	MUST
AU-17	Audit export shall be an asynchronous job producing a downloadable file; the export itself shall be audited, including the filter that was applied and the row count returned.	MUST
AU-18	ADMIN shall be able to read the audit log but shall not be able to alter it. Where an organisation requires it, ADMIN's own actions shall be as fully audited as anyone else's — with no exemption path in code.	MUST

4.7 Personal Data Governance

ID	Requirement	Priority
DG-6	Every field holding personal data shall be classified in a documented inventory: field, classification (identifying, contact, employment, performance, behavioural), lawful purpose, and retention class.	MUST
DG-7	A subject access export shall assemble everything the system holds about one employee — profile, tasks, comments, time entries, reviews, feedback, notifications, and audit events naming them — as a single machine-readable file, produced asynchronously.	SHOULD

ID	Requirement	Priority
DG-8	An erasure routine shall pseudonymise an employee's identifying fields while preserving referential integrity and aggregate history: tasks keep their history, authorship becomes an opaque former-employee reference, and free-text authored by that person is redacted rather than deleted.	SHOULD
DG-9	Erasure shall be refused, with an explanatory error, while a legal hold is in force (DG-4).	MUST
DG-10	Personal data shall never be written to application logs. Log identifiers, not names, addresses, or free text.	MUST

4.8 Endpoints — Part A

Method	Path	Purpose	OK
GET	/audit/events	Query the audit log. Cursor-paginated. AUDITOR/ADMIN.	200
GET	/audit/events/:id	One audit event with its full change payload.	200
POST	/audit/verify	Verify the hash chain over a range; returns the first break.	200
POST	/audit/exports	Queue an audit export job.	202
GET	/audit/exports/:id	Export job state and download reference.	200
GET	/governance/retention-policies	Current retention configuration.	200
POST	/governance/purge-runs	Queue a purge; ?dryRun=true supported.	202
POST	/governance/legal-holds	Place a hold on an employee or task.	201
DELETE	/governance/legal-holds/:id	Lift a hold.	204
POST	/employees/:id/data-export	Queue a subject access export.	202
POST	/employees/:id/erasure	Queue pseudonymisation. HR_ADMIN, refused under hold.	202

5. Part B — Completing the Work Cycle

Phase 2 modelled the middle of the work cycle. This part adds the beginning, the end, and the loops.

5.1 Intake and Triage

ID	Requirement	Priority
WC-1	A TaskRequest shall be introduced: a proposal for work, carrying a title, a description, a requesting employee, a target department, a business justification, and a desired-by date.	MUST
WC-2	Any authenticated employee shall be able to raise a request against any department, including one they do not belong to. This is the one place where cross-department input is open by design.	MUST
WC-3	A request shall have its own lifecycle: SUBMITTED → UNDER_TRIAGE → ACCEPTED DECLINED MERGED. Only ACCEPTED produces a Task.	MUST
WC-4	Declining shall require a reason drawn from a fixed taxonomy (duplicate, out of scope, insufficient information, not now, will not do) plus a free-text note. The requester shall be notified.	MUST
WC-5	MERGED shall record the request it was merged into, so a requester following a duplicate still reaches the live work.	SHOULD
WC-6	Accepting a request shall create a Task in one transaction, carry the description across, link the two permanently, and notify the requester with the new task key.	MUST
WC-7	Triage authority shall follow department management: the department manager, ADMIN, or an employee explicitly designated as a triager for that department.	MUST
WC-8	A triage queue endpoint shall list requests awaiting decision for a department, oldest first, with the age of each request shown.	MUST
WC-9	Time from submission to triage decision shall be recorded, because it is the first metric a requester cares about (Appendix A, <i>triage latency</i>).	SHOULD

5.2 Acceptance Criteria and Definition of Done

ID	Requirement	Priority
WC-10	A task shall carry an ordered list of acceptance criteria, each a short statement with a met/unmet flag and, when met, who marked it and when.	MUST
WC-11	Criteria shall be distinct from checklist items: a checklist is the assignee's working aid and may be edited freely; acceptance criteria define completion and shall be editable only by the creator, the department manager, or ADMIN — and never by the assignee alone.	MUST
WC-12	A department shall be able to define a default Definition of Done: a set of criteria applied automatically to every task created in it.	SHOULD
WC-13	A transition to DONE shall be refused with 422 while any acceptance criterion is unmet, unless the actor is the department manager or ADMIN and supplies an override reason, which shall be audited.	MUST
WC-14	Marking a criterion met shall be recorded in the task activity log, and unmarking a met criterion after review has started shall notify the reviewer.	SHOULD

5.3 Service Levels and Escalation

A due date is a wish. A service level is a commitment with a defined clock, a defined breach, and a defined consequence. Phase 3 introduces the latter.

ID	Requirement	Priority
SL-1	An SLAPolicy shall define, per department and per priority: a response target (time from creation to first assignment) and a resolution target (time from acceptance to DONE), both expressed in working minutes.	MUST
SL-2	Targets shall be measured against a working calendar (§6.1), not wall-clock time. A task raised at 17:00 on Thursday with an eight-hour target is not breached at 01:00 on Friday.	MUST
SL-3	Time spent in BLOCKED shall pause the resolution clock where the policy says so, and the paused duration shall be recorded separately so that the pause itself is visible and auditable.	MUST
SL-4	Each task shall expose its target timestamps, its remaining time, and its breach state (ON_TRACK, AT_RISK, BREACHED), with AT_RISK crossing at a configurable fraction of the target.	MUST
SL-5	Breach and at-risk detection shall be evaluated by a scheduled job as well as computed on read, so that a task nobody opens still raises its escalation.	MUST
SL-6	An escalation shall notify, in order, the assignee, the department manager, and then that manager's manager, at configurable intervals after breach, and shall stop on resolution.	SHOULD
SL-7	Changing a task's priority shall recompute its targets from the moment of the change, without retroactively rewriting history; both the old and new targets shall remain in the record.	MUST
SL-8	SLA state shall never be editable directly through the API. It is derived, always.	MUST

5.4 Approvals and Sign-off

ID	Requirement	Priority
AP-1	A task may require one or more approvals before it may reach DONE. An ApprovalStep shall record its approver (an employee or a role), its order, its state (PENDING, APPROVED, REJECTED, SKIPPED), a decision note, and a decision timestamp.	SHOULD
AP-2	Approval steps shall be evaluated in order; a rejection shall return the task to IN_PROGRESS and shall require a note.	SHOULD
AP-3	An approver shall not be able to approve a task they are assigned to, extending the Phase 2 review rule (TR §6.4) rather than duplicating it.	MUST
AP-4	An approval decision shall be immutable once recorded. Changing one's mind creates a new step, it does not edit the old decision.	MUST
AP-5	Approvals shall be audited as security-relevant events, not merely logged as task activity.	MUST
AP-6	Where an approver is unavailable (§6.3), an ADMIN or the approver's manager may reassign the step, and the reassignment shall be recorded with a reason.	SHOULD

5.5 Rework and Quality Measurement

ID	Requirement	Priority
RW-1	Every return from IN_REVIEW to IN_PROGRESS shall be recorded as a rework event with a category (incomplete, defective, misunderstood requirement, changed requirement, quality standard) and a note.	MUST

ID	Requirement	Priority
RW-2	Every reopening from DONE shall be recorded with the same taxonomy, and shall be distinguished from rework before completion — the two mean different things.	MUST
RW-3	A task shall expose its rework count and reopen count, and both shall feed the first-pass-yield metric (Appendix A).	MUST
RW-4	Rework categories shall be reportable by department and by period, since the distribution is more actionable than the total.	SHOULD

A WORD ON WHAT THIS DATA IS FOR

Rework and reopen counts describe the *system*, not the person. A high rework rate usually means unclear requirements, not a careless engineer. Section 8.6 makes this an enforced constraint rather than a hope: individual-level quality metrics are not permitted as an automatic input to a performance rating. Build the measurement; respect the boundary on its use.

5.6 Closure and Outcome

ID	Requirement	Priority
WC-15	Completing a task shall record an outcome classification: DELIVERED, DELIVERED_PARTIAL, SUPERSEDED, NOT_REPRODUCIBLE, DUPLICATE, WONT_DO.	SHOULD
WC-16	A task may record one or more external references — a URL and a label — to what it produced.	SHOULD
WC-17	A closure note shall be required for any task that breached its SLA or was reopened at least once. Routine tasks shall not require one; ceremony without value is a cost.	SHOULD
WC-18	Cancellation shall use the same outcome taxonomy, so that cancelled work is analysable rather than merely absent.	MUST

5.7 Recurrence and Templates

ID	Requirement	Priority
RC-1	A TaskTemplate shall store a title pattern, description, default priority, default assignee or assignment rule, acceptance criteria, checklist items, tags, and an estimate.	SHOULD
RC-2	A RecurrenceRule shall generate tasks from a template on a schedule — daily, weekly on chosen days, monthly on a day-of-month or nth weekday — with a start date, an optional end date, and a timezone.	SHOULD
RC-3	Generation shall be idempotent per occurrence: a given rule and occurrence date shall produce exactly one task, however many times the job runs.	MUST
RC-4	A rule shall support “generate the next occurrence only when the previous one is complete” as an alternative to fixed-date generation, because the two model genuinely different obligations.	SHOULD
RC-5	Occurrences falling on a non-working day shall be shifted according to a documented policy (before, after, or skip), configured per rule.	SHOULD
RC-6	Pausing a rule shall stop generation without deleting history; already-generated tasks shall be unaffected.	MUST

5.8 Bulk Operations and Saved Views

ID	Requirement	Priority
WC-19	A bulk endpoint shall apply a status transition, an assignment, a tag change, or an archive to up to 200 tasks in one request, returning a per-task result so that partial success is legible.	SHOULD
WC-20	Bulk operations shall evaluate permissions per task, never once for the batch, and shall be executed as a queued job when the batch exceeds a documented size.	MUST
WC-21	A saved view shall store a named filter set, its owner, and a visibility (private, department, organisation), and shall be applicable to the task list in one request.	SHOULD
WC-22	A saved view shall store filter criteria only — never a materialised list of task ids — so that results honour the reader's own permissions at read time.	MUST

5.9 State Duration Tracking

This is the smallest requirement in Part B and the most consequential: without it, none of Part D is possible. Implement it first.

ID	Requirement	Priority
WC-23	Every status transition shall close the current <code>TaskStatusInterval</code> and open a new one, in the same transaction as the transition itself (extending Phase 2's TR-21).	MUST
WC-24	An interval shall record task, status, <code>enteredAt</code> , <code>exitedAt</code> , the actor who caused entry, and a computed duration in seconds, plus a working-hours duration computed against the calendar of §6.1.	MUST
WC-25	Exactly one open interval shall exist per live task at any time. This shall be enforced by a database constraint or a documented equivalent, and shall be covered by a concurrency test.	MUST
WC-26	Historical intervals shall be backfilled from the existing activity log (BC-1). Records derived by backfill shall carry an <code>isEstimated</code> flag, and every metric that includes them shall say so.	MUST
WC-27	Intervals shall be immutable once closed, and shall survive the soft-deletion of their task.	MUST

5.10 Handover and Delegation

ID	Requirement	Priority
WC-28	An employee shall be able to nominate a delegate for a date range. The delegate may act on that employee's approvals and assigned tasks, and every such action shall record both identities (AU-9).	SHOULD
WC-29	Delegation shall not transfer permissions the delegator does not hold, and shall never transfer ADMIN, AUDITOR, or HR_ADMIN capability.	MUST
WC-30	A handover endpoint shall move every active task from one employee to another in a single audited operation, with a report of what moved.	SHOULD

6. Part C — Capacity, Availability & Scheduling

Workload is meaningless without knowing who is actually available. This part supplies the calendar that Parts B and D both depend on.

6.1 Working Calendar

ID	Requirement	Priority
CP-1	A <code>WorkCalendar</code> shall define working days, working hours per day, and a timezone, assignable organisation-wide and overridable per department.	MUST
CP-2	A holiday list shall be maintained per calendar, with dated entries and optional recurrence for fixed-date holidays.	MUST
CP-3	A shared function shall convert any two instants into elapsed <i>working</i> minutes for a given calendar. Every SLA and duration metric shall use it — one implementation, used everywhere.	MUST
CP-4	The conversion shall be correct across daylight-saving transitions and across calendar changes taking effect mid-period, and shall be covered by tests naming those specific cases.	MUST

6.2 Leave and Absence

ID	Requirement	Priority
CP-5	A <code>LeaveRequest</code> shall record employee, type (annual, sick, unpaid, training, other), start and end dates, partial-day indication, note, and state (<code>REQUESTED</code> , <code>APPROVED</code> , <code>REJECTED</code> , <code>CANCELLED</code>).	SHOULD
CP-6	Approval shall follow the reporting line: an employee's manager, or ADMIN. An employee shall never approve their own leave, including a manager approving their own.	MUST
CP-7	Approved leave shall make an employee unavailable for those dates; the system shall warn — not refuse — when a task is assigned to someone on leave, and the warning shall be visible in the response.	SHOULD
CP-8	Leave records shall be visible to the employee, their management chain, and HR_ADMIN. Leave <i>type</i> shall be visible only to the employee and HR_ADMIN; others see availability alone, because sick leave is health data.	MUST
CP-9	A team availability endpoint shall return, for a department and date range, each member's available working hours net of approved leave and holidays.	SHOULD

6.3 Capacity and Load

ID	Requirement	Priority
CP-10	Capacity for an employee over a period shall be computed as available working hours from CP-9, less a configurable non-project overhead percentage.	SHOULD
CP-11	Committed load shall be the sum of remaining estimates on that employee's active tasks whose due dates fall in the period; tasks without estimates shall be counted separately and reported, never silently treated as zero.	SHOULD
CP-12	A workload endpoint shall return capacity, committed load, utilisation percentage, and unestimated task count per employee for a department and period.	SHOULD
CP-13	Utilisation shall be presented with its unestimated-task count alongside it. A utilisation figure computed from partial data and presented as precise is a misleading number, and misleading numbers get people managed badly.	MUST

6.4 Timesheet Approval

ID	Requirement	Priority
CP-14	Time entries (Phase 2, TR-43) shall gain a weekly submission and approval cycle: OPEN → SUBMITTED → APPROVED RETURNED.	SHOULD
CP-15	Approved time entries shall become immutable; correcting one shall require a manager-initiated reopen, which shall be audited.	SHOULD
CP-16	Approval shall follow the reporting line, with the same self-approval prohibition as leave (CP-6).	MUST

7. Part D — Analytics & Reporting

7.1 Principles

- **One definition per metric.** Every metric in Appendix A has exactly one implementation. If two endpoints can disagree about cycle time, the system has no cycle time.
- **Distributions, not averages.** Duration metrics shall be reported as median, 85th and 95th percentile with a sample count. A mean cycle time hides precisely the tail that hurts.
- **Every number carries its sample size.** A percentage over four tasks is an anecdote; it shall be rendered with n so the reader can judge it.
- **Derived data is rebuildable.** The rule of §3.2 applies to every table in this part, without exception.
- **Aggregates respect permissions.** A summary is not a loophole: what a caller may not read individually, they may not read in a total that discloses it.

7.2 Requirements

ID	Requirement	Priority
AN-1	Every metric in Appendix A shall be implemented exactly once, in a shared analytics service, and shall be unit-tested against a fixture with hand-computed expected values.	MUST
AN-2	Duration metrics shall be available in both elapsed and working-hours form, computed via CP-3, and each response shall state which basis it used.	MUST
AN-3	A nightly rollup job shall write a <code>DailyMetricSnapshot</code> per department: WIP by status, throughput, arrivals, backlog size, breach counts, and the duration percentiles for tasks completed that day.	MUST
AN-4	Snapshots shall be immutable once written; a corrected computation shall write a new snapshot version rather than overwriting the old, so that a chart shown yesterday can still be reproduced.	MUST
AN-5	A documented rebuild command shall regenerate all snapshots for any date range from transactional data, and a test shall assert that the rebuilt values equal the incrementally produced ones.	MUST
AN-6	Trend endpoints shall accept a date range and a granularity (day, week, month) and shall return a dense series — periods with no activity present with explicit zeroes, never omitted, because a gap in a series is read as missing data.	MUST
AN-7	Comparison endpoints shall support period-over-period and department-versus-department comparison, returning both absolute and relative change.	SHOULD
AN-8	Analytics queries shall be answered from snapshots and indexed aggregates. No analytics endpoint may load task rows into application memory to compute a figure.	MUST
AN-9	Every analytics response shall carry the timestamp of the data it reflects, so a stale rollup is visible as stale rather than presented as current.	MUST
AN-10	A data-quality endpoint shall report conditions that make metrics untrustworthy: tasks with no estimate, tasks with open intervals older than a threshold, backfilled (estimated) intervals in range, and tasks completed without passing through <code>IN_PROGRESS</code> .	SHOULD
AN-11	Exports of any analytics result shall be available as CSV, produced by the job runner, honouring the caller's permissions and audited under AU-4.	SHOULD
AN-12	Individual-level metrics shall be suppressed where the sample is smaller than a configurable threshold (default 5), returning a documented "insufficient data" marker instead of a number.	MUST

7.3 Dashboards

Dashboard	Audience	Contents
My work	Every employee	Assigned active tasks by priority, items at risk or breached, awaiting-my-approval, my rework rate, my throughput trend.
Department	Manager, ADMIN	WIP by status, aging WIP, arrivals versus completions, breach counts, triage backlog and latency, rework distribution, workload against capacity.
Flow	Manager, ADMIN	Cycle and lead time percentiles over time, time-in-status breakdown, flow efficiency, blocked-time contribution, throughput trend.
Organisation	ADMIN	Cross-department comparison, SLA attainment, backlog growth, capacity utilisation, data-quality summary.

7.4 Endpoints — Part D

Method	Path	Purpose	OK
GET	/analytics/flow	Cycle, lead, and time-in-status percentiles for a scope and range.	200
GET	/analytics/throughput	Completions per period, dense series.	200
GET	/analytics/wip	Current and historical WIP, with aging buckets.	200
GET	/analytics/sla	Attainment, breach counts, at-risk counts.	200
GET	/analytics/quality	Rework, reopen, first-pass yield, by category.	200
GET	/analytics/workload	Capacity, committed load, utilisation (CP-12).	200
GET	/analytics/compare	Period-over-period or department comparison.	200
GET	/analytics/data-quality	Conditions undermining metric reliability (AN-10).	200
POST	/analytics/exports	Queue a CSV export of any of the above.	202
POST	/analytics/rebuild	Rebuild snapshots for a range. ADMIN only.	202

8. Part E — Performance Management & Employee Ratings

8.1 Principles and Constraints

This module holds the most sensitive data in the system and carries real consequences for real people. The following constraints are requirements, not guidance, and each is testable:

ID	Requirement	Priority
PM-1	A rating shall never be computed automatically from task metrics. Metrics may be <i>surfaced as evidence</i> beside a review; the rating itself shall always be entered by a person who is accountable for it.	MUST
PM-2	Any metric shown in a review context shall be displayed with its sample size, its period, and a stated caveat that it measures the flow of work and not the worth of a person.	MUST
PM-3	The system shall not implement forced distribution, stack ranking, or any mechanism that requires a quota of low ratings. If asked to add one later, it is a product decision to be made explicitly and in writing, not a default.	MUST
PM-4	Every rating shall require a written justification of at least 200 characters. A number with no reasoning shall not be submittable.	MUST
PM-5	An employee shall always be able to read their own completed review, add a written response to it, and have that response stored permanently alongside it.	MUST
PM-6	Every read of performance data shall be audited under AU-4, including reads by HR_ADMIN and ADMIN.	MUST
PM-7	Performance data shall be excluded from all generic employee endpoints, all search results, all exports not explicitly scoped to performance, and all analytics endpoints in Part D.	MUST

8.2 Review Cycles

ID	Requirement	Priority
PM-8	A ReviewCycle shall define a name, a period, the participating departments, and per-stage deadlines.	MUST
PM-9	A cycle shall progress through DRAFT → SELF_ASSESSMENT → MANAGER_ASSESSMENT → CALIBRATION → PUBLISHED → CLOSED, with each stage opening and closing the write access appropriate to it.	MUST
PM-10	Opening a cycle shall generate one PerformanceReview per eligible employee, skipping those who joined after a configurable cut-off, and shall record why anyone was skipped.	MUST
PM-11	Stage transitions shall be enforced server-side and shall be irreversible except by HR_ADMIN with an audited reason.	MUST
PM-12	Once a cycle is PUBLISHED, its reviews shall become immutable except for the employee's response (PM-5) and an appended appeal outcome (PM-24).	MUST

8.3 Competencies and the Rating Scale

ID	Requirement	Priority
PM-13	A Competency shall be reference data: name, description, category, and the seniority levels it applies to. The starting library is in Appendix C.	MUST

ID	Requirement	Priority
PM-14	Expectations shall differ by seniority level: the same competency shall carry a level-specific descriptor, so that “Senior” and “Junior” are not judged against one bar.	MUST
PM-15	The rating scale shall be a fixed five-point ordinal scale with defined, published descriptors (Appendix C), stored as reference data.	MUST
PM-16	An overall rating shall be entered explicitly by the reviewer. It shall not be an average of competency scores, and the system shall not compute one; the reviewer may disagree with the arithmetic, and that is legitimate.	MUST

8.4 Assessments

ID	Requirement	Priority
PM-17	A review shall collect a self-assessment (the employee), a manager assessment (their manager), and optional peer feedback (§8.5), each per competency with a score and a comment.	MUST
PM-18	A self-assessment shall not be visible to the manager until the employee submits it, and the manager's assessment shall not be visible to the employee until publication. Both directions matter.	MUST
PM-19	Who may review whom shall follow the reporting line: an employee's direct manager, with HR_ADMIN able to reassign a reviewer where the line is broken or conflicted, with a recorded reason.	MUST
PM-20	A reviewer shall not review themselves, and a reviewer in an unresolved conflict of interest — reviewing their own manager, or a family relationship flagged by HR_ADMIN — shall be blocked with an explanatory error.	MUST

8.5 Peer Feedback

ID	Requirement	Priority
PM-21	An employee or their manager may nominate peer reviewers; nominations shall be approved by the manager before invitations are issued.	SHOULD
PM-22	Peer feedback shall be attributed to its author for HR_ADMIN and the reviewing manager, and presented to the employee in a documented mode — attributed or aggregated — that is fixed per cycle and stated to all participants <i>before</i> they write anything.	MUST
PM-23	Aggregated peer feedback shall be withheld entirely below a minimum of three respondents, since two aggregated comments are trivially de-anonymised.	MUST

8.6 Evidence Linkage

ID	Requirement	Priority
PM-24	A review may attach evidence: specific tasks, closure notes, acknowledgements, or written feedback. Attachment shall be a deliberate act by a person.	SHOULD
PM-25	An evidence panel may display that employee's Part D metrics for the period, subject to PM-1, PM-2, and the suppression threshold of AN-12.	SHOULD
PM-26	Quality metrics attributable to an individual — rework rate, reopen rate — shall be marked in the interface as system-level indicators that require interpretation, and shall never be presented as a performance score.	MUST

8.7 Goals

ID	Requirement	Priority
PM-27	A Goal shall record a title, description, owner, period, measure of success, target and current value, weight, and state (DRAFT, ACTIVE, ACHIEVED, PARTIAL, MISSED, CANCELLED).	SHOULD
PM-28	Goals shall be agreed: creation by either party, activation only after both employee and manager have acknowledged.	SHOULD
PM-29	A goal may link to tasks contributing to it, and shall display their aggregate progress as context — never as an automatic determination of the goal's outcome.	SHOULD
PM-30	Mid-period changes to a goal shall be versioned, not overwritten, so that a goal quietly rewritten near a deadline is visible.	MUST

8.8 Calibration, Publication and Appeal

ID	Requirement	Priority
PM-31	A calibration stage shall let HR_ADMIN and participating managers view a cycle's draft ratings side by side within a scope, and record any change with a mandatory reason.	SHOULD
PM-32	Every calibration change shall retain the original rating in the record. The pre- and post-calibration values shall both be permanently visible to HR_ADMIN and to the employee on publication.	MUST
PM-33	Publication shall notify each employee and open their response window for a configurable period.	MUST
PM-34	An appeal shall be recordable against a published review, with a stated ground, a reviewing authority above the original reviewer, and an outcome (upheld, amended, declined) with reasons. Appeals shall be appended, never edits to the original.	SHOULD
PM-35	A continuous-feedback record — short, dated, attributed notes between manager and employee — shall exist independently of cycles, and shall be available as evidence at review time.	SHOULD

8.9 Visibility Rules

The full matrix is in Appendix D. The governing rules are:

ID	Requirement	Priority
PM-36	An employee may read: their own reviews once published, their own goals, their own feedback, and their own self-assessment at any time.	MUST
PM-37	A manager may read the reviews of their direct and indirect reports for cycles they participated in — and no others, including not their peers' and not their own manager's.	MUST
PM-38	HR_ADMIN may read all performance data. ADMIN — a technical role — shall not be granted performance access by default; where an operational need exists it shall be a separate, audited, time-bounded grant.	MUST
PM-39	Draft assessments shall be readable only by their author until the stage that releases them.	MUST
PM-40	Every rule above shall be covered by a test asserting the denial, not merely the permission.	MUST

8.10 Endpoints — Part E

Method	Path	Purpose	OK
POST	/review-cycles	Create a cycle. HR_ADMIN.	201
POST	/review-cycles/:id/stage	Advance the cycle stage.	200
GET	/review-cycles/:id/progress	Completion by department and reviewer.	200
GET	/reviews/mine	The caller's own reviews, current and historical.	200
GET	/reviews/:id	One review, filtered by the caller's visibility.	200
PUT	/reviews/:id/self-assessment	Save or submit the self-assessment.	200
PUT	/reviews/:id/manager-assessment	Save or submit the manager assessment.	200
POST	/reviews/:id/evidence	Attach a task or note as evidence.	201
POST	/reviews/:id/response	The employee's written response after publication.	201
POST	/reviews/:id/appeal	Raise an appeal.	201
POST	/reviews/:id/peer-invitations	Nominate peer reviewers.	201
POST	/peer-feedback/:token	Submit peer feedback against an invitation.	201
GET	/calibration/:cycleId	Side-by-side draft ratings for a scope.	200
PATCH	/reviews/:id/calibrated-rating	Record a calibration change with a reason.	200
POST	/goals	Create a goal.	201
POST	/goals/:id/acknowledge	Employee or manager acknowledgement.	200
PATCH	/goals/:id/progress	Update the current value.	200
POST	/feedback-notes	Record a continuous-feedback note.	201
GET	/competencies	The competency library with level descriptors.	200

9. Part F — Platform & API Maturity

9.1 Idempotency

ID	Requirement	Priority
PL-1	Every POST that creates a resource shall accept an Idempotency-Key header. The first request with a given key shall be processed and its response stored; a repeat within a documented window shall return the stored response without re-executing.	MUST
PL-2	A key reused with a <i>different</i> request body shall be rejected with 422, since that indicates a client defect rather than a retry.	MUST
PL-3	Idempotency records shall be scoped per caller, shall expire on a documented schedule, and shall be purged by the retention job.	MUST

9.2 Optimistic Concurrency

ID	Requirement	Priority
PL-4	Task, employee, review, and goal responses shall carry an ETag derived from a version column or the update timestamp.	MUST
PL-5	Update endpoints on those resources shall honour If-Match and shall return 412 Precondition Failed when the ETag is stale.	MUST
PL-6	After the deprecation window of BC-3, If-Match shall be required on updates to reviews, goals, and task status. Silent overwrite of a performance record is not an acceptable failure mode.	MUST
PL-7	A 412 response shall include the current ETag so a client can re-fetch, merge, and retry without a second round trip.	SHOULD

9.3 Pagination, Rate Limiting and Integration

ID	Requirement	Priority
PL-8	Cursor pagination shall be available on high-volume collections — audit events, task activity, notifications, time entries — alongside the existing page-based scheme. Cursors shall be opaque and stable under concurrent inserts.	MUST
PL-9	Rate limits shall be applied per authenticated principal and per IP, with 429 responses carrying Retry-After and the documented limit and remaining allowance in headers.	MUST
PL-10	Limits shall be configurable per endpoint class — authentication, read, write, export — because a login endpoint and a task list have nothing in common in this respect.	SHOULD
PL-11	Service accounts shall be supported: non-human principals authenticating with a scoped, revocable API key, holding an explicit permission subset and no interactive login.	SHOULD
PL-12	API keys shall be stored hashed, shown once at creation, carry an optional expiry, and record last-used time. Creation, use, and revocation shall all be audited.	MUST
PL-13	Outbound webhooks shall be deliverable on a subscribed event set, signed with an HMAC over the raw body plus a timestamp, delivered through the job runner with exponential backoff, and disabled automatically after a documented run of consecutive failures.	SHOULD
PL-14	Webhook deliveries shall be recorded with their response status and be individually replayable by an ADMIN.	SHOULD

ID	Requirement	Priority
PL-15	A deprecation policy shall be documented and honoured: a Deprecation and Sunset header on affected endpoints, a stated minimum notice period, and a changelog entry — no endpoint disappears without notice.	MUST

10. Part G — Observability & Operations

ID	Requirement	Priority
OB-1	A liveness endpoint shall report process health, and a readiness endpoint shall report dependency health — database reachable, migrations applied, worker heartbeat recent — with a machine-readable per-check status.	MUST
OB-2	Readiness shall fail when migrations are pending. A process serving traffic against a schema it does not expect is worse than one that is down.	MUST
OB-3	Application metrics shall be exposed in a standard scrape format: request count and latency histograms by route and status, job queue depth and age, job failure counts, database pool utilisation, and rollup staleness.	SHOULD
OB-4	Alert thresholds shall be documented for: readiness failing, dead-letter jobs present, queue age beyond a bound, error rate above a bound, rollup staleness beyond a bound, and audit-chain verification failure — the last being an immediate, unconditional alert.	MUST
OB-5	Every log line shall be structured, shall carry the request id, and shall use levels consistently; log sampling, where used, shall never sample errors.	MUST
OB-6	A runbook shall document, per alert: what it means, how to confirm it, immediate mitigation, and escalation. An alert with no runbook entry shall not be configured.	MUST
OB-7	Backup and restore shall be documented and demonstrated : a written record of an actual restore into a scratch database, with the time it took. An untested backup is a belief, not a control.	MUST
OB-8	Migrations shall be expand-and-contract for any change to a populated table: add, backfill, dual-write or dual-read, switch, then remove — each step separately deployable and reversible.	MUST
OB-9	Performance budgets shall be documented per endpoint class and verified by a repeatable load test against the seeded dataset, with results recorded in the repository.	SHOULD
OB-10	A seed shall exist that produces a realistic dataset at scale — at least 200 employees, 20,000 tasks with history spread over 12 months, leave, reviews, and audit events — because analytics and pagination defects only appear at volume.	MUST

11. Part H — Security & Privacy Hardening

ID	Requirement	Priority
SP-1	Short-lived access tokens shall be paired with refresh tokens; refresh tokens shall rotate on use, and reuse of a consumed refresh token shall invalidate the whole family and raise a security event.	MUST
SP-2	Sessions shall be listable and individually revocable by their owner, and revocable in bulk by ADMIN for any employee. Revocation shall take effect on the next request.	MUST
SP-3	Deactivation, password change, and role change shall each revoke existing sessions.	MUST
SP-4	A password policy shall enforce a documented minimum length, screen against a list of known-breached passwords, and forbid reuse of a documented number of previous passwords. Composition rules that force symbols shall not be used — they are known to produce weaker passwords in practice.	SHOULD
SP-5	Failed logins shall trigger progressive delay and temporary lockout per account and per IP, with the lockout audited and self-clearing.	MUST
SP-6	Optional TOTP-based two-factor authentication shall be available, and shall be enforceable for ADMIN, HR_ADMIN, and AUDITOR.	SHOULD
SP-7	Field-level authorization shall be applied where a caller may read a record but not every field of it — leave type (CP-8), performance data (PM-7), audit payloads. Field filtering shall happen in the serialisation layer, once, not per handler.	MUST
SP-8	Errors shall never disclose the existence of records the caller may not see, extending Phase 2's PR-3 to every new module.	MUST
SP-9	All output shall be escaped contextually; stored strings shall never be rendered as markup. Uploaded or referenced URLs shall be validated against a scheme allow-list.	MUST
SP-10	Dependencies shall be scanned for known vulnerabilities as part of the test command, with findings triaged and recorded rather than ignored.	SHOULD
SP-11	Secrets shall be supplied by environment only, and the application shall refuse to start with a default or empty signing secret rather than starting insecurely.	MUST
SP-12	A written threat model shall accompany Parts A and E: assets, actors, trust boundaries, plausible attacks, and the control that addresses each. One page each is sufficient; absence is not.	SHOULD

12. Non-Functional Requirements

ID	Requirement
NFR-15	The Phase 1 and Phase 2 non-functional requirements remain in force in their entirety.
NFR-16	Analytics endpoints shall respond within 500 ms at the 95th percentile against the OB-10 dataset. Record measured figures in the repository.
NFR-17	The nightly rollup shall complete within 10 minutes on the OB-10 dataset, and shall be safely re-runnable after a partial failure.
NFR-18	No endpoint shall return an unbounded collection; every new collection shall be paginated from the first commit that introduces it.
NFR-19	All money-free numeric aggregates shall be computed in the database. All date arithmetic shall be timezone-explicit; no naive local-time arithmetic anywhere.

ID	Requirement
NFR-20	Test coverage shall include: every state machine in this document, every denial in the visibility matrix, hash-chain verification, calendar arithmetic across DST, idempotency replay, optimistic-concurrency conflict, and rollup-versus-rebuild equality.
NFR-21	The OpenAPI specification shall cover every new endpoint, including error responses, rate-limit headers, and the concurrency headers of §9.2.
NFR-22	Every module shall be independently deployable and independently revertible; a failure in analytics shall not prevent task management from functioning.
NFR-23	Configuration — retention periods, SLA defaults, thresholds, suppression minimums, rate limits — shall be externalised and documented in one place, never hard-coded.

13. Out of Scope — Phase 3

- **Payroll, compensation, and benefits.** Ratings shall not carry a salary implication anywhere in this system.
- **Recruitment, onboarding, and offboarding workflows** beyond the deactivation and handover already specified.
- **Learning management and training records.**
- **Machine learning of any kind** — no predicted completion dates, no sentiment analysis of comments, no automated performance scoring. Explicitly excluded, not merely unbuilt.
- **External BI tool integration.** CSV export is the boundary.
- **Mobile applications and offline support.**
- **Single sign-on, SCIM provisioning, and directory synchronisation.**
- **Multi-tenancy, multi-currency, and multi-language.**
- **Real-time collaborative editing and live-updating dashboards.** Request-driven refresh remains the model.

14. Engineering Process Requirements

Phase 3 assesses how you work as much as what you build. These requirements are graded alongside the code.

ID	Requirement	Priority
PE-1	Before implementing a module, submit a written list of questions and ambiguities found in its section of this document. A module begun with no questions raised will be treated as one that was not read carefully (Day 15).	MUST
PE-2	Before implementing a module, submit a design note of one to three pages: data model changes, affected layers, endpoint contracts, the alternatives you considered, and the risks you see (Day 16). Implementation shall not begin until it is acknowledged.	MUST
PE-3	Each module shall be delivered on its own branch, with commits that are individually coherent and individually revertible (Days 2, 4, 17, 18).	MUST
PE-4	Each pull request shall carry: what changed and why, how it was verified, what was deliberately left out, migration and rollback notes, and a self-review pass completed before requesting review (Day 19).	MUST
PE-5	Review feedback shall be responded to individually — accepted with a change, or disagreed with and reasoned. Silent force-pushes over review comments are not acceptable (Day 20).	MUST
PE-6	Each module shall ship with a short release note in <code>CHANGELOG.md</code> : what a user can now do, what changed for existing behaviour, and what an operator must do to deploy it.	SHOULD
PE-7	Report progress weekly against the milestones of §16 — done, in progress, blocked, and any revised estimate. Report a slipping estimate when it slips, not when it is due.	MUST

15. Deliverables & Acceptance Criteria

15.1 Deliverables

- Per module: a questions list, an acknowledged design note, a branch, a pull request, tests, documentation, and a release note.
- Migrations for every schema change, expand-and-contract where a populated table is touched (OB-8), each independently reversible.
- The scaled seed of OB-10, and the rebuild command of AN-5.
- A test suite meeting NFR-20, runnable with a single documented command.
- An updated OpenAPI specification and browsable docs (NFR-21).
- An operations runbook (OB-6) and a written record of a demonstrated restore (OB-7).
- A personal data inventory (DG-6) and threat models for Parts A and E (SP-12).
- A metrics document stating, for every figure in Appendix A, its exact definition as implemented — the reference a manager reads before trusting a number.
- `docs/decisions.md`, extended with every Phase 3 decision and deviation.

15.2 Acceptance Criteria

Ref.	Acceptance Check
Part A	Every catalogued event is audited including denials; the chain verifies and provably fails on a corrupted row; retention purges in dry-run and live modes; legal hold blocks both purge and erasure; AUDITOR can read everything and change nothing.
Part B	A request can be raised, triaged, declined with a reason, and accepted into a task; SLA state derives correctly against the working calendar with blocked-time pauses; escalation fires from the job runner; acceptance criteria gate completion; rework and reopen are categorised; exactly one open status interval exists per task under concurrent transitions.
Part C	Working-minute arithmetic is correct across DST and holidays; leave approval follows the reporting line with no self-approval; leave type is hidden from non-HR readers; capacity reports unestimated tasks alongside utilisation.
Part D	Every Appendix A metric matches its hand-computed fixture; a full rebuild reproduces incremental values exactly; series are dense; suppression applies below threshold; no analytics endpoint loads rows into memory; every response states its data timestamp.
Part E	The cycle state machine enforces stage-appropriate write access; self-assessments are invisible before submission and manager assessments before publication; no rating is computable without a justification; calibration retains pre-change values; every denial in Appendix D is covered by a test; ADMIN alone cannot read performance data.
Parts F–H	Replayed requests do not duplicate; stale writes return 412 with a current ETag; rate limits return correct headers; webhook signatures verify and failed deliveries retry then disable; readiness fails on pending migrations; refresh-token reuse invalidates the family.
Process	Every module has its questions list, acknowledged design note, self-reviewed PR, and release note, in that order, evidenced in the repository history.

16. Milestones & Sequencing

The order below is not arbitrary. State-duration tracking precedes analytics because analytics is impossible without it; the calendar precedes SLAs for the same reason; audit precedes performance management because performance data must never be readable without a trace. Deviating from the sequence is permitted, but argue for it first.

#	Milestone	Contents	Estimate	Why here
M1	Foundations	§3 job runner, §5.9 status intervals with backfill, §6.1 working calendar.	≈ 5 days	Nothing else is buildable without these three.
M2	Audit core	§4.1–4.4 audit log, event catalogue, hash chain and verification.	≈ 5 days	Every later module writes audit events.
M3	Intake & commitment	§5.1–5.3 requests, triage, acceptance criteria, SLA policies and escalation.	≈ 6 days	Depends on M1's calendar and job runner.
M4	Cycle completion	§5.4–5.8, §5.10 approvals, rework, closure, recurrence, bulk, saved views, delegation.	≈ 6 days	Completes the task lifecycle.
M5	Capacity	§6.2–6.4 leave, availability, capacity, timesheet approval.	≈ 4 days	Feeds workload analytics.
M6	Analytics	§7 metric service, rollups, dashboards, exports, data quality.	≈ 7 days	Depends on M1, M3, M5.
M7	Performance	§8 cycles, competencies, assessments, peer feedback, goals, calibration, appeals.	≈ 8 days	Depends on M2 for audit and M6 for evidence.
M8	Platform hardening	§9, §10, §11 idempotency, concurrency, webhooks, observability, security.	≈ 6 days	Can be interleaved earlier where a specific need arises.

#	Milestone	Contents	Estimate	Why here
M9	Governance completion	§4.5–4.7 retention, purge, legal hold, subject access, erasure.	≈ 4 days	Last, because it must cover every entity that exists.

The total is roughly fifty-one working days at a junior-to-intermediate pace, which is a quarter of engineering work and is stated plainly rather than compressed to look achievable. Agree the subset that is actually in scope before you begin.

Appendix A — Canonical Metric Definitions

Each metric has exactly one implementation (AN-1). Durations are computed in working minutes via CP-3 unless a caller explicitly requests elapsed time.

Metric	Definition	What it is for
Triage latency	$\text{acceptedAt (or declinedAt)} - \text{submittedAt}$, over TaskRequests.	How long a requester waits for an answer.
Lead time	$\text{completedAt} - \text{createdAt}$, over tasks reaching DONE.	Total time from arrival to delivery, as the requester experiences it.
Cycle time	$\text{completedAt} - \text{first entry into IN_PROGRESS}$.	Time from starting to finishing. Excludes queue time.
Reaction time	$\text{first assignment} - \text{createdAt}$.	How long work sits unowned.
Time in status	Σ interval durations per status, per task.	Where time is actually spent. The basis of the two metrics above.
Blocked time	Σ durations in BLOCKED.	Time lost to external waits.
Flow efficiency	$\text{time in IN_PROGRESS} \div \text{lead time}$, as a percentage.	Proportion of elapsed time that was actual work. Typically far lower than people expect.
Throughput	count of tasks entering DONE in a period.	Delivery rate. Counted at the transition, not at the due date.
Arrival rate	count of tasks created in a period.	Demand. Compared against throughput to see backlog direction.
WIP	count of tasks in an active status at an instant.	Concurrent load. Sampled at snapshot time.
Aging WIP	$\text{now} - \text{first entry into IN_PROGRESS}$, for active tasks.	How long current work has been open. The number that finds forgotten tasks.
Backlog size	count of tasks in OPEN, plus untriaged requests.	Committed but unstarted work.
On-time completion	$\text{DONE with completedAt} \leq \text{dueAt} \div \text{DONE with a dueAt set}$.	Reliability against stated dates. Excludes tasks with no date rather than counting them as successes.
SLA attainment	$\text{tasks meeting their resolution target} \div \text{tasks with a policy}$.	Reliability against commitments, not wishes.
Rework rate	$\text{IN_REVIEW} \rightarrow \text{IN_PROGRESS transitions} \div \text{tasks completed}$.	Returns before completion.
Reopen rate	$\text{tasks with } \geq 1 \text{ DONE} \rightarrow \text{OPEN} \div \text{tasks completed}$.	Failures found after completion.
First-pass yield	$\text{tasks completed with zero rework and zero reopens} \div \text{tasks completed}$.	The single clearest quality indicator.
Estimate accuracy	$\text{distribution of loggedMinutes} \div \text{estimateMinutes}$.	Reported as a distribution. A mean ratio is meaningless here.
Utilisation	$\text{committed load} \div \text{capacity}$.	Always published with its unestimated-task count (CP-13).
Carry-over rate	$\text{tasks open at period end that were open at period start} \div \text{open at start}$.	Chronic work that never finishes.

Reporting rules: duration metrics are published as p50, p85, p95 with n; ratio metrics are published with their numerator and denominator; any figure whose sample includes backfilled intervals (WC-26) is flagged.

Appendix B — Audit Event Catalogue

Minimum set. Additions are expected; removals are not.

Category	Events
Authentication	LOGIN_SUCCEEDED, LOGIN_FAILED, LOGOUT, TOKEN_REFRESHED, TOKEN_REUSE_DETECTED, PASSWORD_CHANGED, MFA_ENROLLED, MFA_CHALLENGE_FAILED, ACCOUNT_LOCKED, SESSION_REVOKED
Authorisation	PERMISSION_DENIED, ROLE_GRANTED, ROLE_REVOKED, DELEGATION_STARTED, DELEGATION_ENDED, ELEVATED_ACCESS_GRANTED
Employee records	EMPLOYEE_CREATED, EMPLOYEE_UPDATED, LEVEL_CHANGED, MANAGER_CHANGED, DEPARTMENT_CHANGED, EMPLOYEE_DEACTIVATED, EMPLOYEE_REACTIVATED
Task governance	TASK_DELETED, TASK_RESTORED, TASK_DEPARTMENT_CHANGED, ACCEPTANCE_OVERRIDE_USED, BULK_OPERATION_EXECUTED, SLA_POLICY_CHANGED
Approvals	APPROVAL_GRANTED, APPROVAL_REJECTED, APPROVAL_REASSIGNED
Performance	REVIEW_CYCLE_OPENED, REVIEW_STAGE_ADVANCED, REVIEW_READ, RATING_SUBMITTED, RATING_CALIBRATED, REVIEW_PUBLISHED, APPEAL_RAISED, APPEAL_DECIDED, PEER_FEEDBACK_SUBMITTED
Leave & time	LEAVE_APPROVED, LEAVE_REJECTED, TIMESHEET_APPROVED, TIMESHEET_REOPENED
Data governance	EXPORT_REQUESTED, EXPORT_DOWNLOADED, PURGE_EXECUTED, LEGAL_HOLD_PLACED, LEGAL_HOLD_LIFTED, SUBJECT_ACCESS_EXPORTED, ERASURE_EXECUTED
Platform	API_KEY_CREATED, API_KEY_USED_FIRST_TIME, API_KEY_REVOKED, WEBHOOK_CREATED, WEBHOOK_DISABLED, RATE_LIMIT_TRIGGERED, AUDIT_CHAIN_VERIFICATION_FAILED

Appendix C — Competency Library & Rating Scale

Rating scale

Value	Label	Descriptor
1	Not yet meeting	Consistently below the expectations set for this level; a documented support plan is required.
2	Partially meeting	Meets some expectations; specific, named gaps remain.
3	Meeting	Reliably meets the expectations of the level. This is the expected outcome for a competent employee, not a disappointment.
4	Exceeding	Consistently beyond the level's expectations, with evidence.
5	Outstanding	Performs at the expectations of the level above, sustained across the period.

Starting competency library

Category	Competencies
Delivery	Quality of work · Reliability and follow-through · Ownership of outcomes · Estimation and planning
Craft	Technical depth · Problem decomposition · Code quality and review · Documentation
Collaboration	Communication · Feedback given and received · Cross-team working · Knowledge sharing
Growth	Learning and adaptability · Initiative · Mentoring others (level-dependent)
Judgement	Prioritisation · Risk awareness · Decision quality under uncertainty

Each competency carries a distinct descriptor per seniority level (PM-14). "Mentoring others" applies from Senior upward and shall not be rated for an Intern or Junior.

Appendix D — Visibility Matrix

Y = full read · P = partial, field-filtered · S = self only · — = denied. Every “—” requires a test (PM-40).

Data	Employee	Manager	HR_ADMIN	ADMIN	AUDITOR
Own published review	Y	Y	Y	Y	—
Own draft self-assessment	Y	Y	Y	Y	—
Manager assessment before publication	—	Author only	Y	—	—
Direct report's published review	—	Y	Y	—	—
Indirect report's published review	—	Y	Y	—	—
Peer's review	—	—	Y	—	—
Own manager's review	—	—	Y	—	—
Peer feedback, attributed	Per cycle mode	Y	Y	—	—
Calibration change history	Y (own)	Y (reports)	Y	—	—
Own goals	Y	Y	Y	—	—
Report's goals	—	Y	Y	—	—
Leave dates	S	Y (reports)	Y	P	—
Leave type	S	—	Y	—	—
Own time entries	Y	Y (reports)	Y	P	—
Task data	Per Phase 2	Per Phase 2	Per Phase 2	Y	—
Audit log	—	—	—	Y	Y
Performance data in aggregate analytics	—	—	Y	—	—

Note the two deliberate asymmetries: ADMIN, a technical role, cannot read performance data (PM-38); and AUDITOR can read the audit log but no business content, so that oversight does not become surveillance.

Appendix E — Glossary

Access transparency Auditing of *reads* of sensitive data, not merely writes.

Calibration A moderation step comparing draft ratings across a group before publication, to reduce reviewer-to-reviewer variance.

Cursor pagination Paging by an opaque position marker rather than an offset, so results stay stable while rows are inserted.

Dead letter A job that has exhausted its retries and is set aside for human attention rather than retried forever.

Expand and contract A migration pattern that adds the new shape, moves the data, switches the readers, then removes the old shape — each step separately deployable.

First-pass yield The proportion of work completed with no rework and no reopening.

Flow efficiency Active working time as a proportion of total elapsed time.

Hash chain A sequence in which each record incorporates the hash of its predecessor, so any alteration invalidates everything after it.

Idempotency key A client-supplied identifier letting a server recognise a retried request and return the original result instead of acting twice.

Legal hold A directive suspending deletion of specified records regardless of retention policy.

Optimistic concurrency Allowing concurrent edits but rejecting a write based on stale data, rather than locking in advance.

Read model A structure derived from transactional data and shaped for querying; always rebuildable from its source.

Rework Work returned for correction before it was ever completed, as distinct from a reopening after completion.

Service level A committed target for response or resolution, measured on a working calendar, with a defined breach.

Suppression threshold The minimum sample size below which an individual-level metric is withheld rather than published.

Working minutes Elapsed time counted only within defined working hours, excluding weekends and holidays.

Appendix F — Reference Systems Surveyed

As in Phase 2, what was rejected matters as much as what was adopted.

System	What it does	What StaffDesk takes from it
Jira / Jira Service Management	SLA policies with working calendars and pause conditions; request queues separated from issues; control charts built on status durations.	Adopted: the request-versus-task split (§5.1), calendar-based SLAs with blocked-time pause (§5.3), and status intervals as the basis of all flow metrics (§5.9). Rejected: configurable per-project workflows.
ClickUp / Asana	Recurring tasks, templates, saved views, bulk edit, workload views against capacity.	Adopted: recurrence with idempotent generation (§5.7), saved views storing criteria not results (WC-22), and workload against real availability (§6.3). Rejected: automation rule builders.
Linear	Cycle and lead time percentiles rather than averages; a strong bias toward a small number of well-defined metrics.	Adopted: percentile reporting and the single-definition rule (§7.1, Appendix A).
Lattice / 15Five / Culture Amp	Review cycles with staged visibility, self and manager assessments, 360 feedback, goal agreement, calibration.	Adopted: the cycle state machine (§8.2), staged visibility (PM-18), peer anonymity minimums (PM-23), and calibration with retained originals (PM-32). Rejected: engagement surveys and sentiment scoring.
Workday / BambooHR	Leave with approval chains, working calendars, holiday schedules, and strict separation of HR data from operational data.	Adopted: leave approval by reporting line, health-sensitive field filtering (CP-8), and the HR_ADMIN/ADMIN separation (PM-38). Rejected: payroll and compensation entirely (§13).
Stripe (as an API design reference)	Idempotency keys, cursor pagination, signed webhooks with retries, versioning with explicit deprecation.	Adopted essentially wholesale in Part F (§9), because these are settled solutions and there is nothing to gain from inventing alternatives.
AWS CloudTrail / Google Access Transparency	Comprehensive event catalogues, denial logging, immutable delivery, and auditing of reads of sensitive data.	Adopted: the event catalogue shape (Appendix B), denial logging (AU-2), and access transparency (AU-4). Rejected: external immutable storage, with the limitation stated honestly in §4.4.

Product names are the trademarks of their respective owners and are referenced only to describe well-known design patterns.